Accountable

Penetration Test Report

Acme Health Services

Report Date: **2026-03-23 19:59:58 UTC**

Test Period: **2026-03-23 – 2026-03-23**

Report ID: **TEST-RUN-001**

Classification: **CONFIDENTIAL**

Prepared By: **Accountable HQ**

FINDINGS SUMMARY

3 Vulnerabilities Identified

1 Critical | 1 High | 1 Medium

Table of Contents

1. Executive Summary
2. Scope & Methodology
3. Summary of Findings
4. Detailed Findings
   - 4.1 SQL Injection in Login Endpoint (Critical)
   - 4.2 Cross-Site Scripting (XSS) in Search (High)
   - 4.3 Missing Rate Limiting on Password Reset (Medium)
5. Remediation Roadmap
6. Testing Tools & Techniques
7. Appendix: CVSS Severity Scale
8. Disclaimer & Confidentiality

1. Executive Summary

What This Means: Testing identified 3 vulnerabilities: 1 critical SQL injection, 1 high XSS, and 1 medium missing rate limit.

Findings Overview

Severity	Count	Description
Critical	1	1 critical vulnerability requiring immediate attention
High	1	1 high-severity vulnerability requiring prompt remediation
Medium	1	1 medium-severity finding recommended for remediation
Low	0	No low-severity vulnerabilities identified

Key Takeaways

The application has significant input validation gaps across multiple endpoints.

2. Scope & Methodology

2.1 Scope

The following systems were authorized and included in this penetration test:

Asset	Type
https://example.com	Web Application

2.2 Methodology

Testing followed OWASP WSTG methodology with automated and manual techniques.

2.3 Testing Parameters

Parameter	Detail
Test Type	External Penetration Test + Web Application Assessment
Duration	30m 0s
Report ID	TEST-RUN-001

3. Summary of Findings

All findings sorted by severity with CVSS scores:

ID	Severity	Finding	CVSS	Asset
VULN-0001	Critical	**SQL Injection in Login Endpoint**	9.8	https://example.com
VULN-0002	High	**Cross-Site Scripting (XSS) in Search**	7.1	https://example.com
VULN-0003	Medium	**Missing Rate Limiting on Password Reset**	5.3	https://example.com

4. Detailed Findings

4.1 SQL Injection in Login Endpoint

ID	VULN-0001
Severity	Critical
CVSS Score	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected Asset	https://example.com — /api/login
CWE	CWE-89

What This Means: User input is passed directly to a SQL query without sanitization.

Technical Description

The /api/login endpoint concatenates the username parameter directly into a SQL query string.

Code Locations

src/db/queries.ts:42-45

Unsanitized input used in SQL query

```
const query = `SELECT * FROM users WHERE name = ${name}`;
```

```diff
- const query = `SELECT * FROM users WHERE name = ${name}`;
+ const query = 'SELECT * FROM users WHERE name = $1';
+ const result = await db.query(query, [name]);
```

Evidence

Send a single quote in the username field to trigger a SQL error.

```
curl -X POST https://example.com/api/login -d "user=admin'--&pass=x"
```

Impact

An attacker can extract the entire database, modify data, or escalate privileges.

Remediation Steps

Use parameterized queries instead of string concatenation.

4.2 Cross-Site Scripting (XSS) in Search

ID	VULN-0002
Severity	High
CVSS Score	7.1 (AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N)
Affected Asset	https://example.com — /search
CWE	CWE-79

> **What This Means:** Reflected XSS in the search parameter allows script injection.

Technical Description

The search query parameter is reflected in the response without encoding.

Evidence

Inject a script tag via the search parameter.

```
curl "https://example.com/search?q=<script>alert(1)</script>"
```

Impact

Session hijacking, credential theft, defacement.

Remediation Steps

HTML-encode all user input before rendering in the page.

4.3 Missing Rate Limiting on Password Reset

ID	VULN-0003
Severity	Medium
CVSS Score	5.3
Affected Asset	https://example.com — /api/reset

> **What This Means:** The password reset endpoint has no rate limiting.

Technical Description

No rate limit headers observed; 1000 requests in 10 seconds all returned 200.

Evidence

Send rapid password reset requests.

```
for i in range(1000):
    requests.post('https://example.com/api/reset', json={'email': 'victim@test.com'})
```

Impact

Brute-force attacks on reset tokens or email flooding.

Remediation Steps

Add rate limiting (e.g., 5 requests per minute per IP).

5. Remediation Roadmap

What This Means: This is your to-do list, in priority order. Fix the most severe items first, then work through the rest. Once everything is fixed, contact us for your free re-test.

#	Finding	Action Required	Status
1	**VULN-0001: SQL Injection in Login Endpoint**	Use parameterized queries instead of string concatenation.	**Open**
2	**VULN-0002: Cross-Site Scripting (XSS) in Search**	HTML-encode all user input before rendering in the page.	**Open**
3	**VULN-0003: Missing Rate Limiting on Password Reset**	Add rate limiting (e.g., 5 requests per minute per IP).	**Open**

Recommendations

1. Immediately fix the SQL injection.
2. Implement output encoding for XSS.
3. Add rate limiting to sensitive endpoints.

6. Testing Tools & Techniques

Phase	Tools	Purpose
Reconnaissance	Nmap, Subfinder, DNS enumeration	Service discovery, port scanning, attack surface mapping
Web App Testing	Caido, Nuclei, custom scripts	OWASP Top 10, authentication testing, session analysis
API Testing	Custom scripts, fuzzing tools	Endpoint discovery, input validation, authorization testing
Code Analysis	Semgrep, manual review	Static analysis, pattern matching, vulnerability identification
Exploitation	SQLmap, custom PoC scripts	Vulnerability validation, impact demonstration

7. Appendix: CVSS Severity Scale

Severity	CVSS	Definition	Remediation SLA
Critical	9.0–10.0	Immediate risk; full system compromise or large-scale data breach possible	Immediate (24–48 hrs)
High	7.0–8.9	Significant risk; unauthorized access to sensitive data or systems	14 days
Medium	4.0–6.9	Moderate risk; exploitation requires conditions but could expose data	30 days
Low	0.1–3.9	Minor risk; defense improvement recommended, not immediately exploitable	60 days
Info	0.0	Best practice recommendation with no direct exploitability	Next dev cycle

8. Disclaimer & Confidentiality

Confidentiality Notice

This report is CONFIDENTIAL and intended solely for the authorized recipients. Distribution to other parties requires written consent. Unauthorized distribution may compromise the security of the assessed systems.

Limitations

A penetration test is a point-in-time assessment and cannot guarantee discovery of all vulnerabilities. New vulnerabilities may emerge after testing due to software updates, configuration changes, or newly disclosed threats. Regular testing (at minimum annually) and continuous vulnerability management is recommended.

Liability

This assessment was performed in accordance with industry best practices. All testing was non-destructive and within authorized scope. Remediation decisions remain the sole responsibility of the client.

Accountable HQ

accountablehq.com